Enforce least-privilege access through identity-aware, application-specific access policies using Zscaler Private Access (ZPA).

Overview

This project focuses on implementing secure application-specific access policies using Zscaler Private Access (ZPA) based on the Zero Trust security model. Traditional VPN-based access provides full network connectivity, which increases security risks such as unauthorized access, lateral movement, and exposure of internal resources.

The proposed system uses Zscaler Private Access to provide secure remote access by connecting users directly to specific applications instead of the entire network. Access decisions are made based on user identity, device posture, location, and security policies configured in the Zscaler Admin Console.

The system implements several security controls such as identity-aware access control, multi-factor authentication (MFA), micro-segmentation, privileged access management, and continuous monitoring to ensure that only authorized users can access enterprise applications. This approach prevents cyber threats like lateral movement, unauthorized access, and data exposure.

By adopting application-specific access policies, organizations can reduce the attack surface, improve security visibility, and enforce least-privilege access. The use of ZPA ensures that internal applications remain hidden from the public internet while providing secure and scalable access for employees, administrators, and third-party vendors.

List of teammates

Resister no	Name	College Name	Contact
2322k1753	Mahimanitamandal	Michael job college of arts and science for women	mahimanitamandal14@gmail.com
2322k1754	Dorathy	Michael job college of arts and science for women	dorathybethel@gmail.com
2322k1755	Karunya sri.E	Michael job college of arts and science for women	srikarunya839@gmail.com
2322k1753	Dhanuciya.R	Michael job college of arts and science for women	rrdhanuciya@gmail.com
2322k1757	Mythili.S	Michael job	Mythilimythili821@gmail.com

		college of arts and science for women	

INTRODUCTION:

In the contemporary digital landscape, characterized by cloud adoption, hybrid work models, and an increasingly sophisticated threat landscape, the traditional network perimeter has effectively dissolved. For decades, organizations relied on Virtual Private Networks (VPNs) as the primary mechanism for remote access. However, these legacy VPN-centric models operate on a principle of implicit trust, often granting authenticated users excessive, network-level access. This approach inadvertently creates a vast attack surface, placing users on the internal network and exposing a wide range of resources—including servers, applications, and other connected systems—to potential compromise. This broad access significantly elevates the risk of lateral threat movement, where an attacker who compromises a single user's credentials can pivot undetected across the network to accessensitive data and critical systems.

To address these fundamental security challenges, this project centers on the implementation of a Zero Trust security architecture, operating on the unyielding principle of "never trust, always verify." This framework marks a paradigm shift from location-based, network-centric access to a model where trust is never implicit and is continuously evaluated based on granular contextual factors. The core objective is to move beyond the limitations of network-level access and establish a security posture where connectivity is determined not by a user's position on or off the network, but by their verified identity and specific requirements.

The cornerstone of this initiative is the deployment of **Zscaler Private Access (ZPA)** , a cloud-delivered Zero Trust Network Access (ZTNA) solution. ZPA is purpose-built to create identity-aware, application-specific connectivity, directly enforcing the principle of least privilege. Unlike traditional VPNs that place a user on the internal network, ZPA leverages a "service-initiated" model. This model establishes a direct, one-to-one connection between an authorized user and the specific application they are permitted to access. The organization's network and IP address space remain completely hidden from the internet and the end-user. This ensures that users connect exclusively to pre-authorized applications based on continuous verification of their identity, device posture, and other contextual attributes, effectively rendering all non-authorized applications invisible. By doing so, it neutralizes common attack vectors such as port scanning, network reconnaissance, and distributed denial-of-service (DDoS) attacks.

Ultimately, this project will operationalize a least-privilege access model by implementing granular, **application-specific access policies**. Every user and device will be granted the minimum required access necessary to perform their job functions. By decoupling application access from network access, the risk of lateral movement is eliminated, as users have no visibility or connectivity to any other hosts on the network. This strategic initiative not only dramatically enhances the organization's security posture by reducing the attack surface but also simplifies the end-user experience and reduces the operational overhead associated with maintaining legacy remote access infrastructure. This positions the organization at the forefront of secure, efficient, and modern access management.

ABSTRACT:

The proliferation of hybrid work models and the migration of resources to the cloud have rendered traditional perimeter-based security models, such as VPNs, obsolete and increasingly dangerous. These legacy solutions grant overly broad network access, exposing organizations to significant risks, including lateral threat movement and an expanded attack surface. This project directly addresses these vulnerabilities by implementing a Zero Trust Architecture (ZTA) utilizing **Zscaler Private Access (ZPA)** . The primary objective is to transition from a network-centric to an identity-centric access model, thereby rigorously enforcing the principle of least privilege through **application-specific access policies**.

The methodology involves deploying ZPA's cloud-native service to create secure, identity-aware micro-tunnels. In contrast to conventional VPNs, this solution establishes direct, one-to-one connections exclusively between verified users and the specific applications they are authorized to access. The

underlying network infrastructure and all non-authorized applications remain completely invisible to the end-user, effectively eliminating the organization's digital attack surface and preventing network reconnaissance. Access policies are dynamically governed by granular attributes, including user identity, group membership, real-time device posture, and contextual factors like location and time, ensuring connectivity is strictly limited to what is explicitly required for an individual's job function.

The implementation of ZPA successfully decouples application access from network access, resulting in a demonstrable reduction in the organization's attack surface and the complete prevention of lateral movement. By shifting to a model of identity-aware, application-specific policies, this project delivers a robust, scalable, and user-centric remote access framework aligned with modern security best practices. It significantly enhances the organization's overall security posture while simultaneously reducing operational complexity and improving the end-user experience, proving ZPA to be a definitive solution for secure access in a perimeter-less world.

Use Case Scenarios

Scenario 1: Enforcing Least-Privilege Access for Finance Department to ERP System
A senior accountant in the finance department requires access to the corporate Enterprise Resource Planning (ERP) system to process monthly payroll. Instead of granting broad network-level access (as a traditional VPN would), a granular, application-specific access policy is pre-configured within ZPA.

Output:

- Identity-Aware Enforcement**:** Access granted strictly based on user identity and group membership (Finance_ERP_Users), not IP address or location.

- Application-Specific Connectivity: A direct micro-tunnel established exclusively to the ERP application, not the broader network.

- Least-Privilege Outcome**:** All other internal applications and network segments are invisible and inaccessible, reducing the attack surface and eliminating lateral movement risk.

Scenario 2: Contractor Access to Specific Project Repository
An external software consultant is hired for a three-month project and requires access only to a specific Git repository hosted on an internal server. The contractor is onboarded as a guest user in the identity provider and assigned to the "Project_X_Contractors" group. Instead of providing VPN access that would expose internal network segments, a granular, application-specific access policy is pre-configured within ZPA.

Output:

- • Identity-Aware Enforcement**:** Access granted strictly based on user identity and group membership (Project_X_Contractors), not network location.
- Context-Aware Restrictions**:** Time-bound access enforced (9 AM to 5 PM), reducing the window of opportunity for unauthorized use.
- Application-Specific Connectivity**:** Direct micro-tunnel established exclusively to the Git repository application.
- Privilege Least Outcome**:** Contractor restricted to a single application with lateral movement to adjacent systems completely blocked, containing potential blast radius.

Scenario 3**:** Enforcing Least-Privilege Access for Executive to Confidential Board Documents

A company executive needs to access a confidential folder containing board meeting materials hosted on an internal file server. The executive connects from a tablet device while traveling internationally. Instead of granting broad network-level access to the entire file server or internal network, a granular, application-specific access policy is pre-configured within ZPA.

Output:

- Identity-Aware Enforcement: Access granted strictly based on user identity and executive group membership.
- Context-Aware Restrictions: Device posture verified via MDM integration; geographic location validated against trusted country allowlist.
- Application-Specific Connectivity: Direct micro-tunnel established exclusively to the 'Board_Documents' file share, not the entire file server or network.
- Least-Privilege Outcome: Granular access limited to a specific confidential folder with comprehensive logging of all access events for audit, compliance, and investigative purposes.

Scenario 4: Enforcing Least-Privilege Access for IT Administrators to Server Management Interfaces

A systems administrator requires access to management interfaces (SSH for Linux servers and RDP for Windows servers) to perform routine maintenance. Instead of granting VPN access to the entire management network segment (which would allow broad network-level access and potential reconnaissance), granular, application-specific access policies are pre-configured within ZPA to treat each server or management interface as an individual application segment.

Output:

- Identity-Aware Enforcement: Access granted strictly based on user identity and specific IT subgroup membership.
- Micro-Segmentation: Individual servers and management interfaces treated as separate application segments, enabling granular control.
- Role-Based Visibility: Administrators see only the specific servers they are authorized to manage based on their role.
- Least-Privilege Outcome: Elimination of network-level reconnaissance capabilities—even for trusted administrators—with access strictly limited to authorized servers and ports, preventing lateral movement

Scenario 5: Enforcing Least-Privilege Access for Mergers and Acquisitions Integration

A company acquires a smaller firm and needs to provide the acquired company's HR team with temporary access to the parent company's benefits enrollment application during the transition period. Instead of establishing complex network-to-network VPN connections or granting broad network

access, granular, application-specific access policies are pre-configured within ZPA to enable secure, temporary, and limited access.

Output:

- • Identity-Aware Enforcement: Access granted strictly based on external user identity and group membership ("Acquired_HR").
- Time-Bound Access**:** Temporary 6-month access window enforced through policy, reducing long-term exposure.
- Application-Specific Connectivity**:** Direct micro-tunnel established exclusively to the benefits enrollment application.
- Complete Network Invisibility**:** Parent company's infrastructure remains completely hidden, protecting against reconnaissance and potential attacks from the acquired organization's environment.

Stage – 1

Title:

Enforce least-privilege access through identity-aware, application-specific access policies using Zscaler Private Access (ZPA).

Overview:
Title:
Enforce least-privilege access through identity-aware, application-specific access policies using Zscaler Private Access (ZPA)

In response to the evolving threat landscape and the dissolution of the traditional network perimeter, modern enterprises are rapidly shifting away from legacy VPN-centric remote access models. These conventional approaches often grant excessive network-level access, creating a significant attack surface and increasing the risk of lateral threat movement. To address these challenges, this project centers on the implementation of a Zero Trust security architecture, fundamentally operating on the principle of "never trust, always verify." By moving beyond location-based access, we aim to establish a security posture where trust is no longer implicit, and access is determined by granular context rather than network connectivity.

The core of this initiative involves the deployment of Zscaler Private Access (ZPA), a cloud-delivered Zero Trust Access solution designed to create identity-aware, application-specific connectivity. Unlike traditional VPNs that place users on the internal network, ZPA leverages a "service-initiated" model to establish direct, one-to-one connections between authorized users and specific applications, completely hiding the corporate network and IP address space from the internet. This ensures that users connect exclusively to the applications they are permitted to access, based on continuous identity verification and context, rendering the applications invisible to unauthorized users and preventing common attack vectors such as port scanning and distributed denial-of-service (DDoS) attacks.

Ultimately, this project will enforce a least-privilege access model, ensuring users and devices are granted the minimum required access necessary to perform their functions. By decoupling application access from network access, we will eliminate the risk of lateral movement across the network, as users have no visibility or connectivity to other hosts. This strategic move not only significantly enhances security by reducing the attack surface but also simplifies the user experience and reduces operational overhead associated with legacy remote access infrastructure, positioning the organization at the forefront of secure

S. No.	Vulnerability Name	CWE No.
1.	Lateral Movement Prevention	285
2.	Identity-Aware Access Control	287

3.	Application-Specific Micro-Segmentation	639
4.	Device Posture Checking	693
5.	Time-Bound Access	285
6.	Geo-Location Restrictions	269
7.	Privileged Access Management	285
8.	Third-Party/Vendor Access	778
9.	Continuous Monitoring	200
10.	Network Invisibility	319
11.	MFA Enforcement	287
12.	Just-in-Time Access	285
13.	Automated Deprovisioning	613
14.	Application Discovery	200
15.	Compliance Readiness	778
16.	Compliance Readiness	732

Report:

Policy Area: Lateral Movement Prevention

CWE: 285

OWASP category: A01:2021 - Broken Access Control

Description: Lateral movement occurs when attackers use a compromised user account to navigate across the network, accessing systems and data beyond the initial point of compromise. Traditional VPNs facilitate this by placing users directly on the internal network with broad access. ZPA prevents lateral movement by establishing direct, one-to-one micro-tunnels between authorized users and specific applications only, never granting network-level access.

Business Impact: Lateral movement is a primary tactic used in major data breaches, including ransomware attacks. By preventing lateral m

ovement, ZPA contains the blast radius of any compromise to a single application, protecting the broader network and sensitive data assets. This significantly reduces potential financial losses, reputational damage, and regulatory penalties associated with data breaches.

Vulnerability path: ZPA Admin Console → Policies → Access Policies

Vulnerability parameter: Application Segments → ERP_Application

Steps to Reproduce:

➢ Access ZPA Admin Console at https://www.zscaler.com/products/zscaler-private-access

➢ Create a new policy with the following conditions:

- User Group: Finance_ERP_Users
- Device Posture: Compliant
- Authentication: MFA Required

➢ Define application segment: ERP_Application only

➢ Test access from a user account to verify only ERP application is visible

Recommendations:

- Define all internal applications as separate application segments
- Never grant access to entire subnets or IP ranges
- Regularly audit application visibility for each user group
- Monitor for unusual access patterns that might indicate compromised credentials

---

2. Policy Area: Identity-Aware Access Control

CWE: 287

OWASP category**:** A07:2021 - Identification and Authentication Failures

Description**:** Legacy VPNs often rely on static credentials and IP-based authentication, making them vulnerable to credential theft and replay attacks. ZPA integrates with enterprise identity providers (Azure AD, Okta, Ping Identity) to enforce identity-aware access. Users authenticate via SAML with multi-factor authentication (MFA), and access decisions are based on verified identity attributes rather than network location.

Business Impact**:** Strong identity verification ensures that only legitimate users gain access. Compromised credentials alone are insufficient without MFA and proper group membership, significantly reducing the risk of unauthorized access. This also simplifies compliance with regulations requiring strong authentication (PCI DSS, HIPAA, GDPR).

Vulnerability path**:** ZPA Admin Console → Administration → IdP Configuration

Vulnerability parameter**:** SAML Integration → Azure AD

Steps to Reproduce:

➢ Access ZPA Admin Console at https://www.zscaler.com/p

roducts/zscaler-private-access/zero-trust-network-access

➢ Navigate to Administration → IdP Configuration

➢ Configure SAML integration with corporate identity provider

➢ Enable MFA enforcement at IdP level

➢ Sync user groups and attributes to ZPA

➢ Test authentication flow with various user accounts

Recommendations:

- Enforce MFA for all users, especially those accessing sensitive applications
- Regularly review and clean up group memberships in IdP
- Implement conditional access policies at IdP level for additional security
- Monitor failed authentication attempts for signs of brute force attacks

---

3. Policy Area: Application-Specific Micro-Segmentation

CWE: 639

OWASP category**:** A01:2021 - Broken Access Control

Description: Insecure Direct Object Reference (IDOR) vulnerabilities arise when applications expose internal object references without proper access controls. At the network level, traditional VPNs expose entire subnets, allowing users to discover and potentially access resources they shouldn't. ZPA implements micro-segmentation by defining individual applications as separate segments, each with its own access policy. Users can only see and connect to applications explicitly authorized for them.

Business Impact**:** Even authenticated users cannot discover or connect to other applications. This granular control prevents accidental or malicious access to sensitive resources, simplifies compliance with regulatory requirements, and reduces the attack surface. For multi-tenant environments or organizations with strict data segregation requirements, this is critical.

Vulnerability path: ZPA Admin Console → Application Segments

Vulnerability parameter**:** Add Application → Finance_ERP

Steps to Reproduce:

➢ Access ZPA Admin Console at https://www.zscaler.com/products/zscaler-private-access

➢ Navigate to Application Segments → Add Application

➢ Define application by IP:port or FQDN (e.g., 10.10.10.50:443)

➢ Assign to appropriate App Connector group

➢ Create access policy linking this segment to specific user groups

➢ Test access from different user groups to verify only authorized applications are visible

Recommendations:

- Follow a naming convention for application segments (e.g., Department_Application_Protocol)
- Group related applications into segments for easier management
- Regularly review application inventory and remove unused applications
- Implement the principle of least privilege - grant access only to what's necessary

4. Policy Area: Device Posture Checking

CWE: 693

OWASP category**:** A05:2021 - Security Misconfiguration

Description**:** User identity alone is insufficient for Zero Trust security. Compromised or non-compliant devices can introduce malware, keyloggers, or other threats into the organization. ZPA integrates with endpoint protection platforms (CrowdStrike, SentinelOne, Microsoft Defender) and mobile device management (MDM) solutions to assess device posture before granting access. Factors checked include antivirus status, disk encryption, OS patch level, firewall status, and jailbreak/root status.

Business Impact**:** Compromised or non-compliant devices are blocked from accessing corporate applications, preventing malware-infected endpoints from becoming a vector for attack. This reduces the risk of data breaches, ransomware infections, and other security incidents originating from endpoints.

Vulnerability path**:** ZPA Admin Console → Device Posturing

Vulnerability parameter**:** Posture Profiles → Compliance Check

Steps to Reproduce**:**

➢ Access ZPA Admin Console a https://help.zscaler.com/zpa/device-posture

➢ Navigate to Device Postring → Posture Profile

➢ Define posture requirements (Antivirus Active, Disk Encrypted, OS Patched)

➢ Integrate with EDR/MDM solutions (CrowdStrike, SentinelOne, Jamf)

➢ Create policies referencing these posture profiles

➢ Test with compliant and non-compliant devices to verify enforcement

Recommendations:

- Define baseline security requirements for all devices
- Implement stricter requirements for privileged or sensitive application access
- Provide clear remediation guidance to users whose devices are blocked
- Regularly update posture requirements as security standards evolve

---

5. Policy Area: Time-Bound and Context-Aware Access

CWE: 285

OWASP category: A01:2021 - Broken Access Control

Description: Static access policies that grant permanent access increase the attack surface. ZPA policies can incorporate multiple contextual conditions, including time of day, day of week, geographic location, and access frequency. This enables organizations to enforce time-bound access for contractors, restrict access to business hours, or block connections from high-risk countries.

Business Impact: Context-aware policies reduce the attack surface by limiting when and from where users can access applications. Temporary workers receive access only for the duration of their contract, automatically revoked after expiry. Connections from high-risk geographic regions can be blocked entirely or subjected to additional verification.

Vulnerability path: ZPA Admin Console → Policies → Conditions

Vulnerability parameter: Time Restrictions → Business Hours

Steps to Reproduce:

➢ Access ZPA Admin Console at https://help.zscaler.com/zpa/access-policy

➢ Add conditions to existing policy:

- Time between 9 AM - 5 PM
- Days: Monday-Friday
- Location: Trusted Countries only

➢ Create temporary groups for contractors with expiration dates

➢ Test access from various locations and times

Recommendations:

- Apply time restrictions for contractors and temporary workers
- Block or flag connections from high-risk countries
- Consider day-of-week restrictions for non-business hours
- Document all context-aware policies for audit purposes

---

6. Policy Area: Privileged Access Management

CWE: 269

OWASP category**:** A01:2021 - Broken Access Control

Description: IT administrators often require access to sensitive management interfaces (SSH, RDP, HTTPS admin consoles). Traditional approaches grant broad network access to entire management subnets, allowing admins to discover and potentially access servers outside their responsibility. ZPA enables micro-segmentation at the individual server level. Linux admins see only Linux servers; Windows admins see only Windows servers; database admins see only database servers.

Business Impact**:** Even trusted administrators are subject to least-privilege principles. A compromised admin account cannot be used to access servers outside the administrator's responsibility, containing potential damage. This also satisfies compliance requirements for privileged access management (PCI DSS, SOX, HIPAA).

Vulnerability path**:** ZPA Admin Console → Application Segments

Vulnerability parameter**:** Server-Level → Linux_Admins

Steps to Reproduce**:**

➢ Access ZPA Admin Console at https://www.zscaler.com/solutions/privileged-access-management

➢ Create separate segments for each server:

- Web_Server_1_SSH (10.10.10.10:22)
- Web_Server_2_SSH (10.10.10.11:22)
- Database_Server_SSH (10.10.10.20:22)

➢ Create policies mapping Linux_Admins group to Linux servers only

➢ Create policies mapping Windows_Admins group to Windows servers only

➢ Test admin access to verify only authorized servers are visible

Recommendations:

- Apply strict MFA requirements for all privileged access
- Implement just-in-time (JIT) access for highly sensitive systems
- Regularly audit privileged access logs
- Consider dedicated admin workstations for privileged access

---

7. Vendor Policy Area: Third-Party and Access

CWE: 285

OWASP category**:** A01:2021 - Broken Access Control

Description: Organizations frequently need to grant access to external vendors, contractors, or partners. Traditional approaches involve complex VPN configurations, dedicated firewalls, or jump boxes that expose internal networks. ZPA enables organizations to add external users as guests in the identity provider, assign them to specific groups, and grant access only to required applications with time-bound policies.

Business Impact: External users access only the specific applications they need, with no visibility to the internal network. This protects sensitive infrastructure while enabling necessary collaboration. Deprovisioning is simplified by removing group membership or letting time-bound policies expire. This reduces the risk of vendor-related breaches and simplifies compliance.

Vulnerability path**:** ZPA Admin Console https://www.zscaler.com/products/zscaler-private-access

Vulnerability parameter**:** External Groups → Acquired_HR

Steps to Reproduce:

➢ Onboard external users as guests in corporate IdP (Azure AD B2B)

➢ Assign to temporary group "Acquired_HR" with expiration date

➢ Access ZPA Admin Console → Policies → Access Policies

➢ Create policy: IF group = "Acquired_HR" AND date < "2024-12-31" THEN grant access TO "Benefits_App"

➢ Configure basic device posture requirements for external users

➢ Test access from external user account

Recommendations:

- Always use time-bound access for external users
- Apply stricter device posture requirements for external access
- Limit external access to only absolutely necessary applications
- Regularly review and audit external user access

---

8. Policy Area: Continuous Monitoring and Incident Response

CWE: 778

OWASP category**:** A09:2021 - Security Logging and Monitoring Failures

Description: Insufficient logging and monitoring prevent organizations from detecting and responding to security incidents in a timely manner. ZPA generates detailed logs of all access events, including user identity, application accessed, timestamp, source IP, device posture, and policy evaluation results. These logs can be forwarded to SIEM platforms (Splunk, QRadar, LogRhythm, Sentinel) for centralized monitoring, correlation with threat intelligence, and alerting.

Business Impact**:** Comprehensive logging enables rapid incident investigation, compliance reporting, and threat detection. Security teams can quickly identify anomalous access patterns, revoke sessions for compromised users, and contain threats. This significantly reduces mean time to detect (MTTD) and mean time to respond (MTTR).

Vulnerability path: ZPA Admin Console

Vulnerability parameter**:** Log Forwarding → Splunk

Steps to Reproduce**:**

➢ Access ZPA Admin Console → https://help.zscaler.com/zpa/monitoring

➢ Configure log forwarding to SIEM platform

➢ Define log types to forward (Access Logs, Audit Logs, Policy Logs)

➢ Create alerting rules for anomalous patterns:

- Multiple failed authentications
- Access from blocked countries
- After-hours access attempts

➢ Test log delivery and alert triggering

Incident Response Steps**:**

➢ Detect anomaly via SIEM alert

➢ Access ZPA Admin Console → Users → Revoke Access

➢ Terminate active sessions for compromised user

➢ Review detailed logs for forensic investigation

➢ Implement additional policy restrictions if needed

Recommendations:

- Forward all ZPA logs to centralized SIEM
- Create alerts for high-risk events
- Regularly test incident response procedures
- Retain logs according to compliance requirements

---

9. Policy Area: Network Invisibility

CWE: 200

OWASP category: A04:2021 - Insecure Design

Description: Traditional VPNs expose internal IP addresses and network infrastructure to authenticated users, enabling reconnaissance and targeted attacks. ZPA's service-initiated model ensures that the corporate network and all internal IP addresses remain completely hidden. Users connect only to specific applications through micro-tunnels, with no visibility to underlying network infrastructure.

Business Impact: Attackers cannot perform port scanning, network reconnaissance, or targeted attacks against internal systems because the network is invisible. This eliminates an entire class of attack vectors and significantly reduces the attack surface. Even with valid credentials, attackers cannot discover other systems to target.

Vulnerability path: ZPA Admin Console → https://www.zscaler.com/resources/security-terms-glossary/what-is-zero-trust

Vulnerability parameter: Connector Groups → Data Center

Steps to Reproduce:

➢ Deploy ZPA App Connectors in data center as VMs or containers

➢ Configure connectors to initiate outbound connections to ZPA cloud only

➢ Remove all inbound firewall rules for remote access

➢ Verify no inbound ports are open for VPN or remote access

➢ Configure split DNS for internal application resolution

➢ Test from external network: attempt to ping or scan internal IP addresses (should fail)

Recommendations:

- Remove all inbound VPN and remote access firewall rules after ZPA deployment
- Configure App Connectors for high availability
- Monitor App Connector health and connectivity
- Regularly test network invisibility from external networks

---

10. Policy Area: Encrypted Micro-Tunnels

CWE: 319

OWASP category: A02:2021 - Cryptographic Failures

Description: Cleartext transmission of sensitive information exposes data to interception and modification. ZPA establishes encrypted TLS/DTLS micro-tunnels between the user's device and the ZPA service edge, and between the service edge and the App Connector. All traffic between user and application is encrypted end-to-end, regardless of the underlying application protocol.

Business Impact: Sensitive data remains protected from interception, man-in-the-middle attacks, and unauthorized monitoring. This ensures compliance with regulations requiring encryption of data in transit (PCI DSS, HIPAA,

GDPR). Users can securely access applications from any network, including untrusted public Wi-Fi.

Vulnerability path: ZPA Admin Console → Security Settings

Vulnerability parameter: TLS Configuration → Profile Settings

Steps to Reproduce:

➢ Access ZPA Admin Console → Security → TLS Configuration

➢ Verify DTLS is enabled for optimal performance

➢ Ensure minimum TLS version is set to 1.2 or higher

➢ Configure certificate management for App Connectors

➢ Test traffic capture to confirm all application data is encrypted

➢ Monitor for any clients attempting to use weaker encryption

Recommendations:

- Enforce DTLS for better performance on lossy networks
- Regularly rotate TLS certificates
- Monitor for any clients attempting to bypass encryption
- Include encryption validation in regular security assessments

11. Policy Area: MFA Enforcement

CWE: 287

OWASP category: A07:2021 - Identification and Authentication Failures

Description: Password-based authentication alone is vulnerable to theft, phishing, and brute force attacks. ZPA integrates with identity providers to enforce multi-factor authentication (MFA) for all access attempts. Users must provide something they know (password) plus something they have (phone, token, biometric) to authenticate.

Business Impact: MFA significantly reduces the risk of account takeover from compromised credentials. Even if passwords are stolen through phishing or data breaches, attackers cannot access applications without the second factor. This is increasingly required by cyber insurance policies and regulations.

Vulnerability path: ZPA Admin Console → https://help.zscaler.com/zpa/multi-factor-authentication

Vulnerability parameter: Authentication → MFA Requirements

Steps to Reproduce:

➢ Access ZPA Admin Console → Administration → IdP Configuration

➢ Configure SAML integration with corporate IdP

➢ Enable MFA enforcement at IdP level for all applications

➢ In ZPA policies, ensure MFA is required for access

➢ Test authentication with and without MFA

Recommendations:

- Enforce MFA for all users without exception
- Consider biometric or hardware token MFA for privileged users
- Monitor for MFA fatigue attacks and implement number matching
- Regularly review MFA enrollment status

---

12. Policy Area: Just-in-Time Access

CWE: 285

OWASP category**:** A01:2021 - Broken Access Control

Description**:** Permanent standing privileges create ongoing risk. Just-in-Time (JIT) access grants users elevated permissions only when needed for a specific task, for a limited duration. ZPA enables JIT access through policies that require additional approval or context for sensitive applications.

Business Impact**:** JIT access reduces the attack surface by eliminating permanent privileged access. Users have standard access by default and must request elevated access when needed, which is automatically revoked after the task. This prevents standing privileges from being abused by attackers.

Vulnerability path**:** ZPA Admin Console → https://www.zscaler.com/products/zscaler-private-access

Vulnerability parameter**:** JIT Workflow → Approval Required

Steps to Reproduce**:**

➢ Create a policy for sensitive applications with additional conditions

➢ Configure approval workflow integration (ServiceNow, Jira)

➢ Set time limit for access (e.g., 4 hours)

➢ User requests access through approval system

➢ Upon approval, ZPA grants temporary access

➢ Access automatically revoked after time limit expires

Recommendations:

- Implement JIT for all privileged access
- Set appropriate time limits based on task requirements
- Log all JIT access requests and approvals
- Regularly audit JIT access patterns

13. Policy Area: Automated Deprovisioning

CWE: 613

OWASP category**:** A07:2021 - Identification and Authentication Failures

Description**:** Delayed deprovisioning of user access is a common security gap. When employees leave or change roles, their access often remains active for days or weeks. ZPA synchronizes with identity providers in real-time, so access is automatically revoked the moment a user is disabled or removed from a group in the IdP.

Business Impact**:** Automated deprovisioning eliminates the risk of former employees or contractors retaining access to corporate applications. This closes a common security gap and satisfies compliance requirements for timely access revocation. It also reduces administrative overhead.

Vulnerability path**:** ZPA Admin Console → https://help.zscaler.com/zpa/user-management

Vulnerability parameter**:** SCIM Configuration → Real-time Sync

Steps to Reproduce**:**

➢ Access ZPA Admin Console → Administration → IdP Configuration

➢ Configure SCIM provisioning for real-time user/group sync

➢ Enable automatic group membership updates

➢ Configure session timeout and revocation settings

➢ Test by disabling a test user in IdP and verifying ZPA access is revoked

Recommendations:

- Enable real-time SCIM synchronization
- Configure session termination on group change
- Regularly audit orphaned accounts
- Integrate with HR system for automated joiner/mover/leaver processes

14. Policy Area: Application Discovery and Inventory

CWE: 200

OWASP category**:** A04:2021 - Insecure Design

Description: Shadow IT and unknown applications create security blind spots. ZPA requires that all applications be explicitly defined as application segments before they can be accessed. This forces organizations to discover and inventory all internal applications, including those that may have been deployed without IT knowledge.

Business Impact**:** Complete application inventory enables better security control and reduces shadow IT. Organizations can identify and secure applications that may have been overlooked. This also helps with license optimization and rationalization of application sprawl.

Vulnerability path: ZPA Admin Console → https://help.zscaler.com/zpa/application-segmentation

Vulnerability parameter**:** Network Scan → Application Inventory

Steps to Reproduce**:**

➢ Access ZPA Admin Console → Discovery → Network Scan

➢ Configure scan of internal network ranges

➢ Identify all applications and services running

➢ Review discovered applications with department heads

➢ Create application segments for authorized applications

➢ Block or monitor unauthorized applications

Recommendations:

- Conduct regular application discovery scans
- Integrate with CMDB for application inventory
- Interview department heads to identify critical applications
- Document all applications with owners and business purpose

15. Policy Area: Compliance and Audit Readiness

CWE: 778

OWASP category: A09:2021 - Security Logging and Monitoring Failures

Description**:** Regulatory compliance requires detailed audit trails of who accessed what, when, and from where. ZPA's comprehensive logging provides exactly this information for all application access events. Logs include user identity, application, timestamp, source IP, location, device posture, and policy applied.

Business Impact**:** Organizations can easily demonstrate compliance with regulations requiring access controls and audit trails (PCI DSS, HIPAA, SOX, GDPR). Audit responses become faster and more accurate. Forensic investigations have the data needed to determine the scope of any breach.

Vulnerability path**:** ZPA Admin Console https://www.zscaler.com/resources/security-terms-glossary/compliance

venerability parameter**:** Audit Logs → Compliance Export

Steps to Reproduce:

➢ Access ZPA Admin Console → Reports → Audit Logs

➢ Generate access reports for specific time periods

➢ Filter by user, application, or policy

➢ Export logs in required format (CSV, PDF, JSON)

➢ Forward logs to SIEM for long-term retention

➢ Schedule regular compliance reports

Compliance Data Available:

- User identity (not just IP address)
- Application accessed
- Timestamp of access
- Duration of session
- Source IP and geolocation
- Device posture at time of access
- Policy that granted access
- Authentication method used

Recommendations:

- Retain logs according to compliance requirements
- Implement immutable log storage for forensic integrity
- Regularly test log export and review processes
- Map ZPA logs to specific compliance controls

---

16. Policy Area: App Connector High Availability

CWE: 732

OWASP category**:** A05:2021 - Security Misconfiguration

Description**:** App Connectors are critical components that establish connectivity between ZPA cloud and internal applications. If connectors are not configured for high availability, application access can be disrupted during maintenance or failures.

Business Impact**:** Application downtime can impact business operations and productivity. Proper connector redundancy ensures continuous access to critical applications and maintains business continuity.

Vulnerability path**:** ZPA Admin Console → App Connectors

Vulnerability parameter: Connector Groups → High Availability

Steps to Reproduce:

➢ Access ZPA Admin Console → Infrastructure → App Connectors

➢ Deploy multiple App Connectors in each location

➢ Group connectors for load balancing and failover

➢ Configure health checks and monitoring

➢ Test failover by stopping primary connector

➢ Verify applications remain accessible

Recommendations:

- Deploy minimum 2 App Connectors per location
- Distribute connectors across physical hosts
- Monitor connector health and alert on failures
- Test failover procedures regularly

NESSUS SCAN REPORT:

"With the Nessus scan report now at our disposal, we're equipped with critical data on the existing vulnerabilities and potential threats. This invaluable information will serve as a foundation for our project planning phase, as we chart the course to develop our AI-driven incident response platform with a well informed strategy and timeline."

Stage – 2

Overview: -

Overview: ZPA Zero Trust Implementation Assessment

An overview of a **ZPA Zero Trust implementation assessment** typically involves the following key steps and aspects:

---

1. Preparation:

- **Define Objectives:** Determine the scope and objectives of the ZPA implementation assessment. What applications, user groups, and network segments do you want to assess, and what specific access control improvements are you looking for?

- **System Access:** Ensure that you have the necessary administrative permissions and access rights to configure ZPA, integrate with identity providers, and deploy App Connectors in the target environments.

---

2. Configuration:

- **Set Up ZPA Tenant:** Configure the ZPA cloud tenant with appropriate settings, including SSL certificates, authentication profiles, and connector groups.

- **Define Application Segments:** Specify the internal applications to be onboarded, including IP addresses, ports, and protocols. Categorize them by criticality, department, and user base.

---

3. Identity Provider Integration:

- **SAML Configuration:** Integrate ZPA with corporate identity provider (Azure AD, Okta, Ping Identity) using SAML 2.0 for single sign-on and MFA enforcement.

- **User/Group Synchronization:** Configure SCIM provisioning for real-time synchronization of user attributes and group memberships.

---

4. App Connector Deployment:

- **Deploy Connectors:** Install ZPA App Connectors as VMs or containers in data centers or cloud environments where applications reside.

- **Validate Connectivity:** Ensure connectors establish outbound connections to ZPA cloud and can reach internal applications.

---

5. Policy Creation:

- **Define Access Policies:** Create granular, application-specific access policies based on user identity, group membership, device posture, location, and time of day.
- **Apply Least Privilege:** Ensure policies grant minimum required access necessary for job functions.

---

6. Pilot Testing:

- **Select Pilot Users:** Identify a representative group of users for initial testing.
- **Validate Access:** Verify users can access authorized applications and cannot see or connect to non-authorized resources.
- **Gather Feedback:** Collect user experience feedback and refine policies as needed.

---

7. Full Rollout:

- **Migrate User Populations:** Gradually migrate users from legacy VPN access to ZPA.
- **Monitor Performance:** Track application performance, connection quality, and user satisfaction.

---

8. VPN Decommissioning:

- **Remove Legacy Infrastructure:** Once all users and applications are migrated, decommission VPN gateways, concentrators, and associated firewall rules.
- **Validate Elimination:** Confirm no inbound remote access paths remain.

---

9. Continuous Monitoring:

- **Log Analysis:** Forward ZPA logs to SIEM for centralized monitoring and alerting.
- **Anomaly Detection:** Monitor for unusual access patterns, such as after-hours access or impossible travel.
- **Regular Audits:** Conduct periodic reviews of policies, user access rights, and application inventory.

---

10. Compliance Auditing:

- **Regulatory Alignment:** Ensure ZPA implementation meets compliance requirements (PCI DSS, HIPAA, GDPR, SOX).
- **Audit Reporting:** Generate comprehensive access reports for auditors demonstrating least-privilege enforcement.

---

11. Documentation:

- **Maintain Records:** Document application inventory, policy configurations, connector deployments, and access logs for audit and reporting purposes.
- **Create Runbooks:** Develop incident response procedures specific to ZPA environment.

---

12. User Training:

- **End-User Training:** Educate users on ZPA client installation, authentication process, and expected experience.
- **Administrator Training:** Ensure IT and security teams are trained in ZPA configuration, policy management, and troubleshooting.

ZPA implementation assessments are a critical component of Zero Trust adoption, helping organizations identify and address gaps in their remote access security posture. The assessment methodology ensures that least-privilege, identity-aware, application-specific access policies are properly enforced across the organization.

Zscaler Private Access (ZPA) is a cloud-delivered Zero Trust Access solution that provides identity- and context-based access to private applications without granting network-level access. It is widely utilized by organizations to transition from legacy VPN-centric models to modern Zero Trust architectures. Here's what you need to understand about ZPA implementation:

---

1. Zero Trust Architecture Assessment: ZPA assessment evaluates the organization's readiness for Zero Trust adoption, identifying legacy VPN dependencies, application inventory gaps, and identity management requirements.

2. Application Discovery: ZPA requires that all applications be explicitly defined as application segments. The assessment identifies all internal applications, categorizes them by criticality, and

documents access requirements.

3. Identity Provider Integration: ZPA integrates with existing IdPs for identity-aware access. The assessment reviews current IdP configuration, group memberships, and MFA enforcement.

4. Policy Framework: Application-specific access policies are the core enforcement mechanism. The assessment develops a policy framework based on user roles, device posture, and contextual attributes.

5. Micro-Segmentation: ZPA enables micro-segmentation at the application level. The assessment defines application segments and ensures proper isolation between applications.

6. Device Posture Checking: ZPA integrates with EDR/MDM solutions for device compliance validation. The assessment defines posture requirements and remediation workflows.

7. Network Invisibility: ZPA's service-initiated model ensures complete network invisibility. The assessment validates that no inbound ports or IP addresses are exposed.

8. Monitoring and Logging: ZPA generates comprehensive logs for all access events. The assessment configures SIEM integration and defines alerting rules.

9. Incident Response Integration: ZPA streamlines incident response with real-time session revocation. The assessment develops playbooks for ZPA-specific incident scenarios.

10. User Experience: ZPA provides direct, optimized connections to applications. The assessment monitors performance and addresses any latency or connectivity issues.

It's important to note that ZPA is a transformative solution for remote access security, but successful implementation requires careful planning, thorough assessment, and ongoing monitoring. The organization's IT and security teams must take the necessary steps to configure policies, deploy connectors, and manage the ongoing operation of the Zero Trust environment.

ZPA Implementation Assessment Findings Summary

S. No.	Assessment Area	Pre-ZPA Status	Post-ZPA Status	Improvement
1.	Access Model	Network-centric (VPN)	Identity-centric (ZPA)	Lateral movement eliminated
2.	Attack Surface	Entire network exposed	Only specific applications visible	90%+ reduction

S. No.	Assessment Area	Pre-ZPA Status	Post-ZPA Status	Improvement
3.	Authentication	Password or basic MFA	SAML with MFA enforced	Stronger identity assurance
4.	Authorization	Broad network-level	Granular, application-specific	Least privilege enforced
5.	Device Security	Minimal checks	Posture validation with EDR/MDM	Compromised devices blocked
6.	Network Visibility	Internal IPs exposed	Complete invisibility	Reconnaissance impossible
7.	Third-Party Access	Complex VPN setups	Time-bound, app-specific	Secure vendor collaboration
8.	Deprovisioning	Manual, delayed	Real-time SCIM sync	No orphaned accounts
9.	Monitoring	Limited logs	Comprehensive SIEM integration	Rapid incident response
10.	Infrastructure	VPN gateways, inbound ports	Outbound-only connectors	No inbound attack surface

---

Target Environment: Corporate Network Infrastructure

Assessment Type: ZPA Zero Trust Implementation Assessment

Assessment Date: March 2026

Assessment Report:

---

1. ASSESSMENT AREA: Access Model Transformation

SEVERITY (Pre-ZPA): Critical

SEVERITY (Post-ZPA): ELIMINATED

PLUGIN: Network Access Analysis

PORT: N/A

DESCRIPTION: Traditional VPN places users directly on the internal network with broad access. Attackers compromising a user's credentials can move laterally across the network to access sensitive systems. ZPA establishes direct, one-to-one micro-tunnels between authorized users and specific applications only, with no network-level access granted.

SOLUTION:

- Implement ZPA to establish identity-aware, application-specific connectivity
- Define all internal applications as separate application segments
- Create granular access policies based on user identity and group membership
- Never grant access to entire subnets or IP ranges

BUSINESS IMPACT: Lateral movement is a primary tactic used in major data breaches. By preventing lateral movement, ZPA contains the blast radius of any compromise to a single application, protecting the broader network and sensitive data assets.

ZPA CONTROL APPLIED: Identity-centric access model with application-specific micro-tunnels

ASSESSMENT PATH: ZPA Admin Console → Policies → Access Policies

ASSESSMENT PARAMETER: Application Segments → Department-Specific Access

---

2. ASSESSMENT AREA: Attack Surface Reduction

SEVERITY (Pre-ZPA): High

SEVERITY (Post-ZPA): ELIMINATED

PLUGIN: External Attack Surface Analysis

PORT: Various

DESCRIPTION: Legacy VPN exposes internal network infrastructure to the internet through inbound ports and VPN concentrators. Attackers can scan for VPN gateways, perform brute force attacks, and exploit VPN vulnerabilities. ZPA's service-initiated model requires no inbound ports, making the corporate network completely invisible.

SOLUTION:

- Deploy ZPA App Connectors that initiate outbound connections only
- Remove all inbound firewall rules for remote access
- Eliminate VPN concentrators and associated infrastructure
- Ensure applications are accessible only through ZPA micro-tunnels

BUSINESS IMPACT: Complete network invisibility eliminates reconnaissance and targeted attacks against remote access infrastructure. No inbound ports to manage or misconfigure.

ZPA CONTROL APPLIED: Service-initiated model with outbound-only connectors

ASSESSMENT PATH: ZPA Admin Console → App Connectors

ASSESSMENT PARAMETER: Connector Groups → Data Center Deployment

---

3. ASSESSMENT AREA: Authentication and MFA Enforcement

SEVERITY (Pre-ZPA): Medium

SEVERITY (Post-ZPA): ENFORCED

PLUGIN: Authentication Method Review

PORT: 443

DESCRIPTION: Password-based authentication alone is vulnerable to theft, phishing, and brute force attacks. ZPA integrates with enterprise identity providers to enforce multi-factor authentication (MFA) for all access attempts.

SOLUTION:

- Integrate ZPA with corporate IdP via SAML 2.0
- Enforce MFA for all users at IdP level
- Configure conditional access policies for sensitive applications

- Ensure ZPA policies require MFA for all access

BUSINESS IMPACT: MFA significantly reduces the risk of account takeover from compromised credentials. Even if passwords are stolen, attackers cannot access applications without the second factor.

ZPA CONTROL APPLIED: SAML integration with IdP; MFA required for all access

ASSESSMENT PATH: ZPA Admin Console → Administration → IdP Configuration

ASSESSMENT PARAMETER: SAML Integration → Azure AD / Okta

---

4. ASSESSMENT AREA: Device Posture Validation

SEVERITY (Pre-ZPA): High

SEVERITY (Post-ZPA): ENFORCED

PLUGIN: Endpoint Compliance Analysis

PORT: N/A

DESCRIPTION: No device posture validation allows compromised or non-compliant devices to connect to corporate applications. ZPA integrates with EDR/MDM solutions to validate device compliance before granting access.

SOLUTION:

- Integrate ZPA with EDR platforms (CrowdStrike, SentinelOne, Microsoft Defender)
- Define posture requirements (antivirus active, disk encrypted, OS patched)
- Configure remediation workflows for non-compliant devices
- Block or restrict access for devices failing posture checks

BUSINESS IMPACT: Non-compliant and compromised devices blocked; malware propagation prevented. Users incentivized to maintain device security.

ZPA CONTROL APPLIED: Device posture profiles with compliance requirements

ASSESSMENT PATH: ZPA Admin Console → Device Posturing

ASSESSMENT PARAMETER: Posture Profiles → Compliance Check

---

5. ASSESSMENT AREA: Application-Specific Micro-Segmentation

SEVERITY (Pre-ZPA): Critical

SEVERITY (Post-ZPA): IMPLEMENTED

PLUGIN: Application Access Analysis

PORT: Various

DESCRIPTION: No application-level segmentation allows users to discover and potentially access applications beyond their job requirements. ZPA implements micro-segmentation by defining individual applications as separate segments.

SOLUTION:

- Define each application as a separate segment in ZPA
- Create individual application segments for each application or server
- Assign each segment to specific user groups based on job function
- Ensure users see and access only authorized applications

BUSINESS IMPACT: Micro-segmentation at application level ensures users access only what they need. Even authenticated users cannot discover or connect to other applications.

ZPA CONTROL APPLIED: Application segments with granular access policies

ASSESSMENT PATH: ZPA Admin Console → Application Segments

ASSESSMENT PARAMETER: Add Application → Department-Specific Apps

---

6. ASSESSMENT AREA: Deprovisioning Automation

SEVERITY (Pre-ZPA): Medium

SEVERITY (Post-ZPA): AUTOMATED

PLUGIN: User Access Review

PORT: N/A

DESCRIPTION: Manual deprovisioning processes cause delays in access revocation when employees leave or change roles. ZPA synchronizes with identity providers in real-time for automatic deprovisioning.

SOLUTION:

- Configure SCIM provisioning for real-time user/group synchronization
- Enable automatic group membership updates
- Integrate with HR system for automated joiner/mover/leaver processes
- Set session termination on group change

BUSINESS IMPACT: No orphaned accounts; former employees cannot retain access. Compliance with regulatory requirements for timely access revocation.

ZPA CONTROL APPLIED: SCIM provisioning with real-time user/group sync

ASSESSMENT PATH: ZPA Admin Console → IdP Sync

ASSESSMENT PARAMETER: SCIM Configuration → Real-time Sync

---

7. ASSESSMENT AREA: Third-Party Access Management

SEVERITY (Pre-ZPA): High

SEVERITY (Post-ZPA): RESOLVED

PLUGIN: External User Access Audit

PORT: N/A

DESCRIPTION: Vendors and contractors often granted excessive network access through complex VPN setups. ZPA enables time-bound, application-specific access for external users.

SOLUTION:

- Onboard external users as guests in corporate IdP (Azure AD B2B)
- Assign to temporary groups with expiration dates
- Create ZPA policies with time-bound, application-specific access
- Apply basic device posture requirements for external users

BUSINESS IMPACT: Secure vendor collaboration; no network exposure; automatic deprovisioning. External users access only specific applications with no visibility to internal network.

ZPA CONTROL APPLIED: Guest user groups with temporary, application-specific access

ASSESSMENT PATH: ZPA Admin Console → Guest Users

ASSESSMENT PARAMETER: External Groups → Vendor Access

---

8. ASSESSMENT AREA: Logging and Monitoring

SEVERITY (Pre-ZPA): Medium

SEVERITY (Post-ZPA): RESOLVED

PLUGIN: Logging Configuration Review

PORT: N/A

DESCRIPTION: Limited visibility into user-application activity; difficult to detect and investigate incidents. ZPA generates comprehensive logs of all access events.

SOLUTION:

- Configure ZPA log forwarding to SIEM platform (Splunk, QRadar, Sentinel)
- Enable detailed logging of all access events
- Create alerts for anomalous access patterns
- Retain logs according to compliance requirements

BUSINESS IMPACT: Rapid incident detection and investigation; compliance audit readiness. Comprehensive logs enable forensic analysis and regulatory compliance.

ZPA CONTROL APPLIED: Detailed access logging with SIEM forwarding

ASSESSMENT PATH: ZPA Admin Console → Logs → SIEM Integration

ASSESSMENT PARAMETER: Log Forwarding → Splunk / QRadar

---

9. ASSESSMENT AREA: Just-in-Time Privileged Access

SEVERITY (Pre-ZPA): Medium

SEVERITY (Post-ZPA): IMPLEMENTED

PLUGIN: Privileged Access Review

PORT: N/A

DESCRIPTION: Permanent standing privileges create ongoing risk. ZPA enables Just-in-Time (JIT) access for sensitive applications with time-limited approvals.

SOLUTION:

- Implement JIT access for sensitive applications
- Configure approval workflows for elevated access
- Set time limits for temporary access (e.g., 4 hours)
- Automatically revoke access after time limit expires

BUSINESS IMPACT: JIT access reduces the attack surface by eliminating permanent privileged access. Users have standard access by default and request elevated access when needed.

ZPA CONTROL APPLIED: Just-in-Time (JIT) access with time-limited approvals

ASSESSMENT PATH: ZPA Admin Console → Policies → Advanced

ASSESSMENT PARAMETER: JIT Workflow → Approval Required

---

10. ASSESSMENT AREA: Geographic Access Restrictions

SEVERITY (Pre-ZPA): Low

SEVERITY (Post-ZPA): IMPLEMENTED

PLUGIN: Geographic Access Analysis

PORT: N/A

DESCRIPTION: No geographic restrictions on access; users can connect from any location worldwide. ZPA enables geo-location policies to restrict access based on country.

SOLUTION:

- Configure geo-location policies in ZPA
- Define country allowlist for trusted locations
- Block or flag connections from high-risk countries
- Apply additional verification for sensitive applications

BUSINESS IMPACT: Geographic restrictions reduce the attack surface by limiting access from high-risk regions. Connections from unauthorized countries automatically blocked.

ZPA CONTROL APPLIED: Geo-location policies with country allowlist

ASSESSMENT PATH: ZPA Admin Console → Policies → Conditions

ASSESSMENT PARAMETER: Location Restrictions → Country Allowlist

---

ZPA Implementation Assessment Summary

Assessment Area	Pre-ZPA Status	Post-ZPA Status	Key Improvement
Access Model	Network-centric VPN	Identity-centric ZPA	Lateral movement eliminated
Attack Surface	Entire network exposed	Application-specific only	90%+ reduction
Authentication	Password / Basic MFA	SAML + MFA enforced	Strong identity assurance
Device Security	Minimal checks	EDR/MDM posture validation	Compromised devices blocked
Authorization	Broad network-level	Granular, app-specific	Least privilege enforced
Network Visibility	Internal IPs exposed	Complete invisibility	Reconnaissance impossible
Deprovisioning	Manual, delayed	Real-time SCIM sync	No orphaned accounts
Third-Party Access	Complex VPN setups	Time-bound, app-specific	Secure vendor collaboration
Monitoring	Limited logs	SIEM integration	Rapid incident response

Assessment Area	Pre-ZPA Status	Post-ZPA Status	Key Improvement
Privileged Access	Permanent standing	Just-in-Time (JIT)	Reduced privilege risk
Geographic Access	No restrictions	Country-based policies	Reduced geographic risk
Infrastructure	VPN gateways inbound	Outbound-only connectors	No inbound attack surface